Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 7. UNE-ISO 31000. 2018 Gestión del Riesgo. Directrices

Índice

Esquema

Ideas clave

7.1. Introducción y objetivos

7.2. Directrices de la UNE-ISO 31000:2018

7.3. Principios de la UNE-ISO 31000:2018

7.4 Marco de referencia de la UNE-ISO 31000:2018

7.5. Proceso de la UNE-ISO 31000:2018

7.6. Referencias bibliográficas

A fondo

Modelo basado en metodologías de gestión de riesgos de ti para contribuir en la mejora de la seguridad de los activos de información

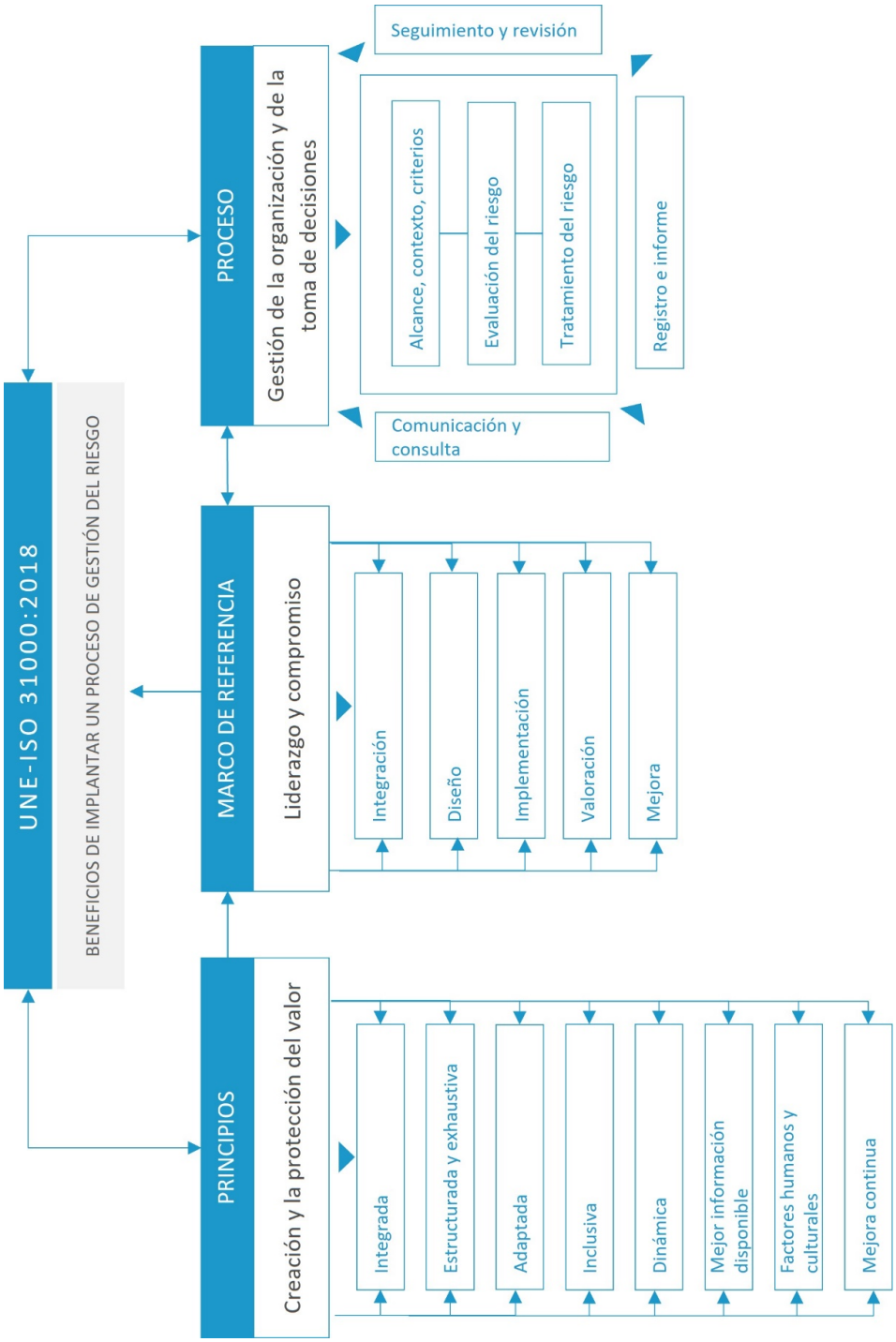
Ciberamenazas y Tendencias. Edición 2021

Gestión de Riesgo. Una guía de aproximación para el empresario

Análisis de riesgos dinámicos en sistemas de información

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

7.1. Introducción y objetivos

El objetivo fundamental de este tema es comprender los aspectos más relevantes del enfoque de la gestión orientada al riesgo así como su correcto desempeño según la norma ISO 31000:2018 como base para la gestión de riesgos.

Más concretamente, los objetivos principales de este tema son los siguientes:

- Conocer y comprender los principios y directrices aplicables a la gestión de riesgos.
- Identificar los beneficios de la implantación de una gestión de riesgos a la gestión general de la organización.
- Conocer el marco de referencia y el desempeño para la gestión de riesgos.
- Conocer los procesos de gestión de riesgos, para poder diseñar e implantar la gestión de riesgos como pilar estratégico.
- Conocer los métodos para el tratamiento de los riesgos.

La gestión de riesgos es una actividad crítica para que las organizaciones puedan alcanzar sus objetivos y mejorar su desempeño en todas las áreas.

La Norma ISO 31000 se ha convertido en una referencia internacional que proporciona principios y directrices a las empresas de cualquier sector y de cualquier tamaño que quieran integrar la gestión de riesgos en sus actividades.

Se abordarán los términos y conceptos más relevantes en la gestión de riesgos, así como las directrices para su implantación, siguiendo la estructura de la norma ISO 31000.

© Universidad Internacional de La Rioja (UNIR)

7.2. Directrices de la UNE-ISO 31000:2018

Esta norma proporciona a las organizaciones una herramienta para **gestionar el riesgo,** que no es otra cosa que la **incertidumbre que generan los factores e influencias tanto internas como externas a las que está expuesta una organización y que pueden poner en peligro el cumplimiento de sus objetivos.**

Todas las actividades de una organización implican riesgos que deben ser capaces de afrontar. Para ello, las organizaciones deben gestionar el riesgo identificándolo, analizándolo y evaluándolo, para determinar si es necesario modificarlo mediante un tratamiento que satisfaga sus criterios de riesgo.

Para ello, a lo largo de todo el proceso de gestión de riesgos, las organizaciones deben **comunicar y consultar a las partes interesadas** aquellos aspectos que les afecten y llevar a cabo una **revisión y seguimiento** tanto del **riesgo** como de los **controles** que lo modifican, con el objetivo de tener un conocimiento del nivel de riesgo al que está expuesta y facilitar la información necesaria para la toma de decisiones, implantando tratamientos del riesgo adicionales cuando sea necesario.

La **UNE-ISO 31000** establecen una serie de **principios** que se deben satisfacer para que la **gestión de riesgos** sea **eficaz.** Para ello, recomienda a las organizaciones que deben desarrollar e implementar un marco de referencia cuyo objetivo sea integrar dicho proceso en los procedimientos de gobierno, de estrategia y de planificación, de gestión y de elaboración de informes, así como en las políticas, los valores y en la cultura de toda la organización. Todo ello dentro de un trabajo de mejora continua.

Esta norma es un enfoque común para gestionar cualquier tipo de riesgo, en cualquier industria de cualquier sector, de una manera sistemática, transparente y fiable, dentro de cualquier alcance y de cualquier contexto. Son características que le

© Universidad Internacional de La Rioja (UNIR)

hacen idónea para su utilización en la gestión de riesgos en organizaciones de cualquier sector y tamaño. Asimismo, esta norma puede utilizarse a lo largo de la vida de la organización y puede aplicarse a cualquier actividad, incluyendo la toma de decisiones en todos los niveles.

Uno de los puntos clave de esta norma consiste en la inclusión del «establecimiento del contexto» como una actividad al comienzo de este proceso de gestión de riesgos. El establecimiento del contexto permite captar los objetivos de la organización, el entorno en el que se persiguen estos objetivos, las partes interesadas y la diversidad de los criterios de riesgo. Todos estos elementos contribuyen a mostrar y evaluar la naturaleza y complejidad de sus riesgos.

Características de una gestión de riesgo eficaz y eficiente:

- Es iterativa y asiste a las organizaciones para establecer sus estrategias, lograr sus objetivos y tomar decisiones informadas.
- Es parte de la gobernanza y el liderazgo y es fundamental en la manera en que se gestiona la organización en todos sus niveles. Esto contribuye a la mejora de los sistemas de gestión.
- Es parte de todas las actividades asociadas con la organización e incluye la interacción con las partes interesadas.
- Considera los contextos externo e interno de la organización, incluido el comportamiento humano y los factores culturales.
- La gestión de riesgos está basada en los principios, el marco de referencia y el proceso descritos en la norma.

Un **proceso de gestión de riesgos** implantado según los principios y directrices de la UNE-ISO 31000 es una herramienta que ayuda a una organización a:

- Aumentar la probabilidad de alcanzar los objetivos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Fomentar una gestión proactiva.
- Ser consciente de la necesidad de identificar y tratar el riesgo en toda la organización.
- Mejorar la identificación de oportunidades y de amenazas.
- Cumplir los requisitos legales y reglamentarios.
- Mejorar la redacción de informes obligatorios y voluntarios.
- Mejorar el gobierno.
- Mejorar la seguridad y la confianza de las partes interesadas.
- Establecer una base fiable para la toma de decisiones y la planificación.
- Mejorar los controles.
- Asignar y utilizar de manera eficaz los recursos para el tratamiento del riesgo.
- Mejorar la eficacia y la eficiencia operacional.
- Aumentar las prestaciones en materia de salud y seguridad, así como la protección ambiental.
- Mejorar la prevención de pérdidas y la gestión de incidentes.
- Minimizar las pérdidas.
- Mejorar el aprendizaje de la organización.
- Mejorar la resiliencia de la organización.

© Universidad Internacional de La Rioja (UNIR)

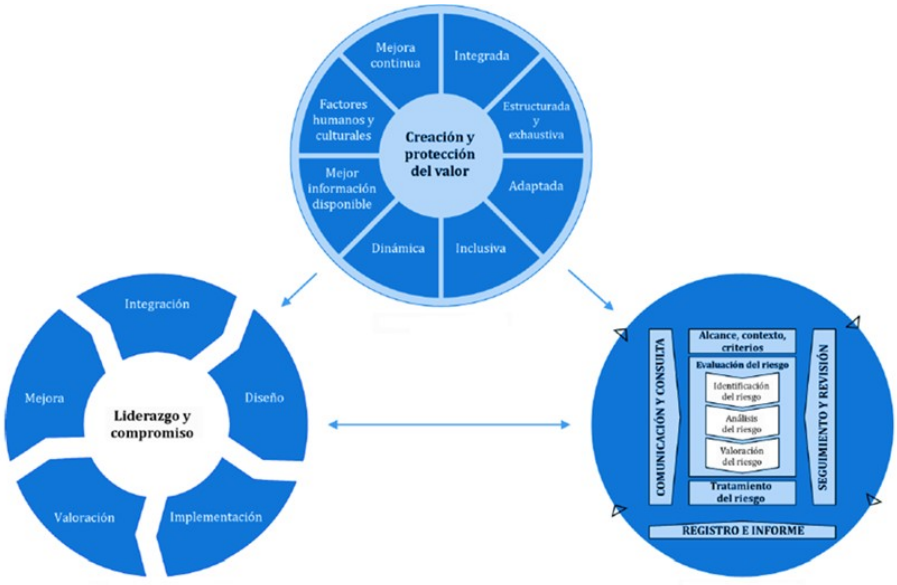


Figura 1. Principios, marco de referencia y proceso. Fuente: UNE-ISO 31000:2018 (2018), p. 6.

© Universidad Internacional de La Rioja (UNIR)

7.3. Principios de la UNE-ISO 31000:2018

La UNE-ISO 31000 establece una serie de principios que deben aplicarse en la gestión de riesgos para que esta sea eficaz. Estos deben ser adoptados por la organización en la gestión de riesgos en todos sus niveles.

El propósito de la gestión de riesgos es la creación y la protección del valor. Mejora el desempeño, fomenta la innovación y contribuye al logro de objetivos.

Los principios que se describen a continuación proporcionan orientación sobre las características de una gestión de riesgos eficaz y eficiente, comunicando su valor y explicando su intención y propósito. Estos son el fundamento de la gestión de riesgos y se deberían considerar cuando se establece el marco de referencia y los procesos de gestión de riesgos de la organización. Estos principios deberían habilitar a la organización para gestionar los efectos de la incertidumbre sobre sus objetivos.

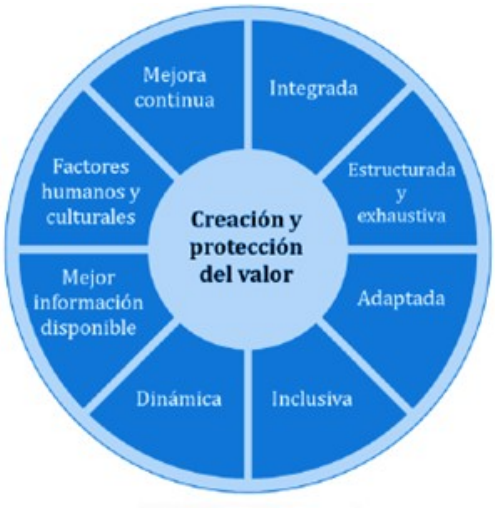


Figura 2. Principios. Fuente: UNE-ISO 31000:2018 (2018), p. 9.

Integrada

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La gestión de riesgos no debe ser una actividad independiente y separada del resto de las actividades y procesos principales de la organización. Forma parte de las responsabilidades de gestión y es una parte integral de todos los procedimientos de la organización, incluyendo tanto la planificación estratégica como a todos los procesos de la gestión de proyectos y de cambios.

Estructurada y exhaustiva

Un enfoque estructurado y exhaustivo hacia la gestión de riesgos contribuye a resultados coherentes y comparables.

Adaptada

El marco de referencia y el proceso de la gestión de riesgos se adaptan y son proporcionales a los contextos externo e interno de la organización relacionados con sus objetivos.

Inclusiva

La participación apropiada y oportuna de las partes interesadas permite que se consideren su conocimiento, puntos de vista y percepciones. Esto resulta en una mayor toma de conciencia y una gestión de riesgos informada.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Dinámica

Los riesgos pueden aparecer, cambiar o desaparecer con las variaciones de los contextos externo e interno de la organización. La gestión de riesgos anticipa, detecta, reconoce y responde a esos cambios y eventos de una manera apropiada y oportuna.

Mejor información disponible

Las entradas a la gestión de riesgos se basan en información histórica y actualizada, así como en expectativas futuras. La gestión de riesgos tiene en cuenta explícitamente cualquier limitación e incertidumbre asociada con tal información y expectativas. La información debería ser oportuna, clara y disponible para las partes interesadas pertinentes.

Factores humanos y culturales

El comportamiento humano y la cultura influyen considerablemente en todos los aspectos de la gestión de riesgos en todos los niveles y etapas.

La gestión de riesgos permite identificar las aptitudes, las percepciones y las intenciones de las personas externas e internas que pueden facilitar o dificultar el logro de los objetivos de la organización.

© Universidad Internacional de La Rioja (UNIR)

Mejora continua

La gestión de riesgos mejora continuamente mediante aprendizaje y experiencia.

La organización debe desarrollar e implementar estrategias para mejorar su madurez en la gestión de riesgos en todos los demás aspectos de la organización.

© Universidad Internacional de La Rioja (UNIR)

7.4 Marco de referencia de la UNE-ISO 31000:2018

El éxito de la gestión de riesgos en una organización depende de la eficacia del marco de referencia de gestión que utilice y que deben proporcionarle las bases y las disposiciones que le permitan su integración a todos los niveles en la gobernanza de la organización, incluyendo la toma de decisiones, lo que requiere el apoyo de las partes interesadas, particularmente de la alta dirección. El desarrollo del marco de referencia implica integrar, diseñar, implementar, valorar y mejorar la gestión de riesgos a lo largo de toda la organización.



Figura 3. Marco de referencia. Fuente: UNE-ISO 31000:2018 (2018), p. 11.

El marco de referencia debe facilitar una gestión eficaz del riesgo mediante la aplicación del proceso de gestión de riesgos a diferentes niveles y dentro de contextos específicos de la organización, garantizando que la información obtenida en este proceso se comunique y utilice adecuadamente como una base para la toma de decisiones, estableciendo la obligación de rendir cuentas a todos los niveles pertinentes en la organización.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Las organizaciones deberían valorar sus prácticas y procesos actuales de la gestión de riesgos, valorar cualquier brecha y abordar estas brechas en el marco de referencia, igualmente, deberían adaptar los componentes del marco de referencias y su forma de trabajo en interrelación a las necesidades específicas de la organización.

Liderazgo y compromiso



Figura 4. Liderazgo y compromiso. Fuente: adaptado de UNE-ISO 31000:2018 (2018), p. 11.

La alta dirección y los órganos de supervisión, cuando sea aplicable, deberían asegurar que la gestión de riesgos esté integrada en todas las actividades de la organización y deberían demostrar el liderazgo y compromiso mediante:

- La adaptación e implementación de todos los componentes del marco de referencia.
- La publicación de una declaración o una política que establezca un enfoque, un plan o una línea de acción para la gestión de riesgos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- La aseguración de que los recursos necesarios se asignen para gestionar los riesgos.

© Universidad Internacional de La Rioja (UNIR)

- La asignación de autoridad, responsabilidad y obligación de rendir cuentas en los niveles apropiados de la organización.

Esto ayudará a la organización a:

- Alinear la gestión de riesgos con sus objetivos, estrategia y cultura.
- Reconocer y abordar todas las obligaciones, así como sus compromisos voluntarios.
- Establecer la magnitud y el tipo de riesgo que puede o no ser tomado para guiar el desarrollo de los criterios del riesgo, asegurando que se comuniquen a la organización y a sus partes interesadas.
- Comunicar el valor de la gestión de riesgos a la organización y sus partes interesadas.
- Promover el seguimiento sistemático de los riesgos.
- Asegurarse de que el marco de referencia de la gestión de riesgos permanezca apropiado al contexto de la organización.

La alta dirección rinde cuentas por gestionar el riesgo mientras que los órganos de supervisión informen por la supervisión de la gestión de riesgos. Frecuentemente se espera o se requiere que los órganos de supervisión se aseguren de que:

- Los riesgos se consideren apropiadamente cuando se establezcan los objetivos de la organización.
- Los sistemas para gestionar estos riesgos se implementen y operen eficazmente.
- Estos riesgos sean apropiados en el contexto de los objetivos de la organización.
- La información sobre estos riesgos y su gestión se comunique de la forma apropiada.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Y que comprendan los riesgos a los que hace frente la organización en la búsqueda de sus objetivos.

© Universidad Internacional de La Rioja (UNIR)

Integración



Figura 5. Integración. Fuente: adaptado de UNE-ISO 31000:2018 (2018), p. 11.

La integración de la gestión de riesgos depende de la comprensión de las estructuras y el contexto de la organización. Las estructuras, a su vez, difieren dependiendo del propósito, las metas y la complejidad de la organización. De esta forma, el riesgo se gestiona en cada parte de la estructura de la organización y todos los miembros de una organización tienen la responsabilidad de gestionar el riesgo.

La gobernanza guía el curso de la organización, sus relaciones externas e internas y

© Universidad Internacional de La Rioja (UNIR)

las reglas, los procesos y las prácticas necesarios para alcanzar su propósito. Las estructuras de gestión convierten la orientación del gobiernoa en la estrategia y los objetivos asociados requeridos para lograr los niveles deseados de desempeño sostenible y de viabilidad en el largo plazo. La determinación de los roles para la rendición de cuentas y la supervisión de la gestión de riesgos dentro de la organización son partes integrales de la gobernanza de la organización.

La integración de la gestión de riesgos en la organización es un proceso dinámico e iterativo y se debería adaptar a las necesidades y a la cultura de la organización. La gestión de riesgos debería ser una parte de y no estar separada del propósito, la gobernanza, el liderazgo y compromiso, la estrategia, los objetivos y las operaciones de la organización.

Diseño

La segunda fase dentro del marco de referencia es el diseño.



Figura 6. Integración. Fuente: adaptado de UNE-ISO 31000:2018 (2018), p. 11.

© Universidad Internacional de La Rioja (UNIR)

En la fase de diseño se deben realizar varias actividades:

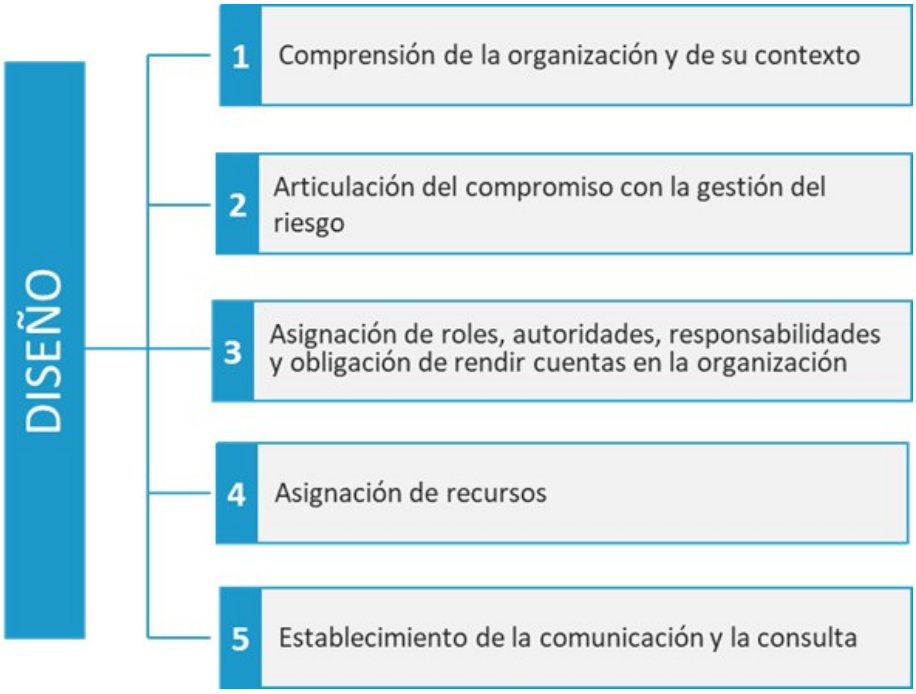


Figura 7. Actividades a realizar durante la fase de diseño. Fuente: elaboración propia.

A continuación se describe cada una de las actividades que forman parte de la fase de diseño del marco de referencia.

© Universidad Internacional de La Rioja (UNIR)

Comprensión de la organización y de su contexto

La organización debería analizar y comprender sus contextos externo e interno cuando diseñe el marco de referencia para gestionar el riesgo.

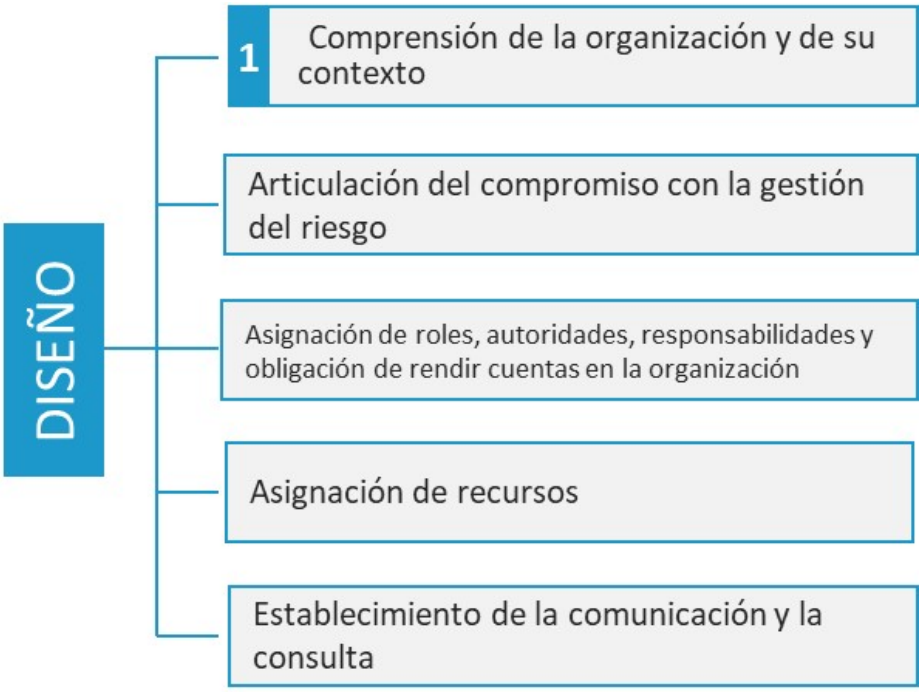


Figura 8. Comprensión de la organización y de su contexto. Fuente: elaboración propia.

Establecimiento del contexto externo: el contexto **externo** es el entorno externo en que la organización busca conseguir sus objetivos.

La **comprensión del contexto externo** es importante para asegurarse de que los objetivos e inquietudes de las partes interesadas externas se tienen en cuenta cuando se desarrollan los criterios de riesgo. El contexto externo se basa en el contexto a escala de la organización, pero con detalles específicos de **requisitos legales y reglamentarios** con las percepciones de las partes interesadas y con otros aspectos de riesgos específicos del alcance del proceso de gestión de riesgos.

© Universidad Internacional de La Rioja (UNIR)

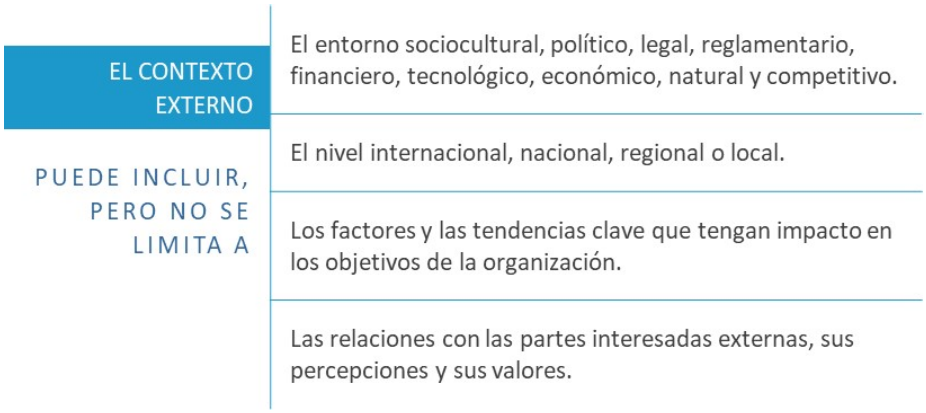


Figura 9. Objetos que abarca el contexto externo. Fuente: elaboración propia.

Establecimiento del contexto interno: es el **entorno interno** en que la organización busca conseguir sus objetivos. El proceso de gestión de riesgos debe alinearse con la cultura, los procedimientos, la estructura y la estrategia.

Lo constituye **todo aquello que en el seno de la organización puede influir en la manera en la que tratará el riesgo.** Este contexto se debe establecer, ya que la gestión de riesgos se realiza en el contexto de los **objetivos de la organización.** Los objetivos y los criterios de un proyecto, de un proceso o de una actividad específicos se deben considerar en relación con los objetivos de la organización en su conjunto y algunas organizaciones no reconocen todas las **oportunidades** que les permiten conseguir sus objetivos en materia de estrategia, de proyecto o de negocio, lo que afecta a la continuidad del compromiso, la credibilidad, la confianza y los valores de esta.

© Universidad Internacional de La Rioja (UNIR)

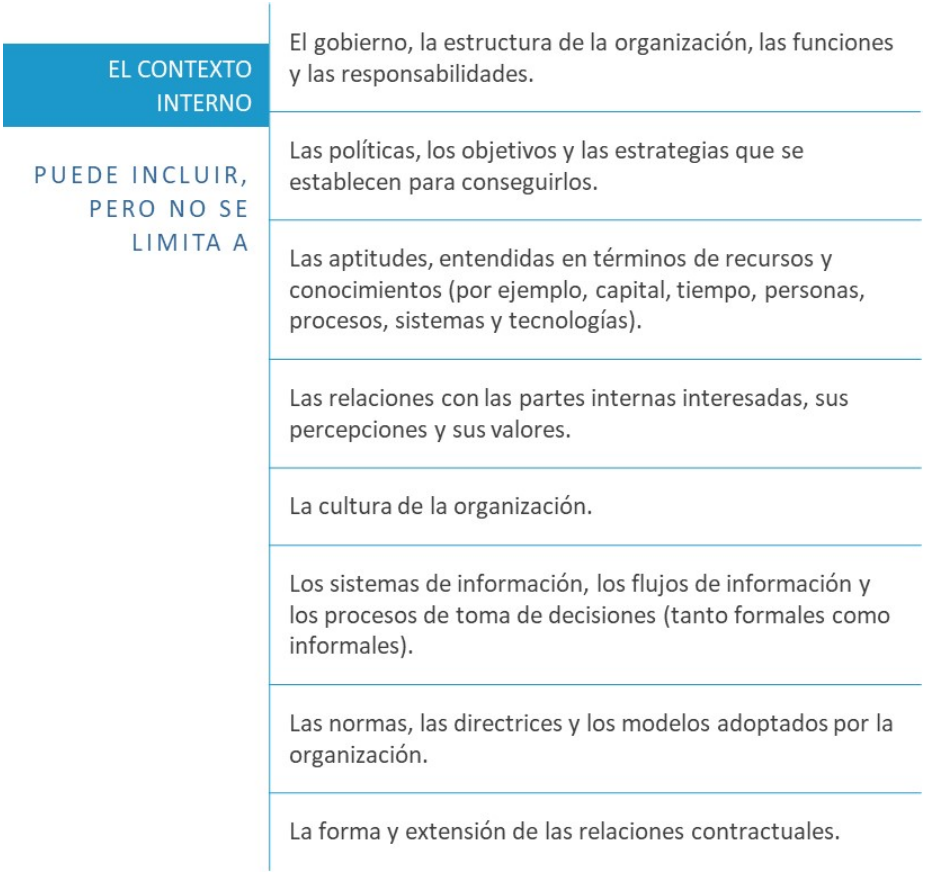


Figura 10. Objetos que abarca el contexto interno. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

Articulación del compromiso con la gestión de riesgos

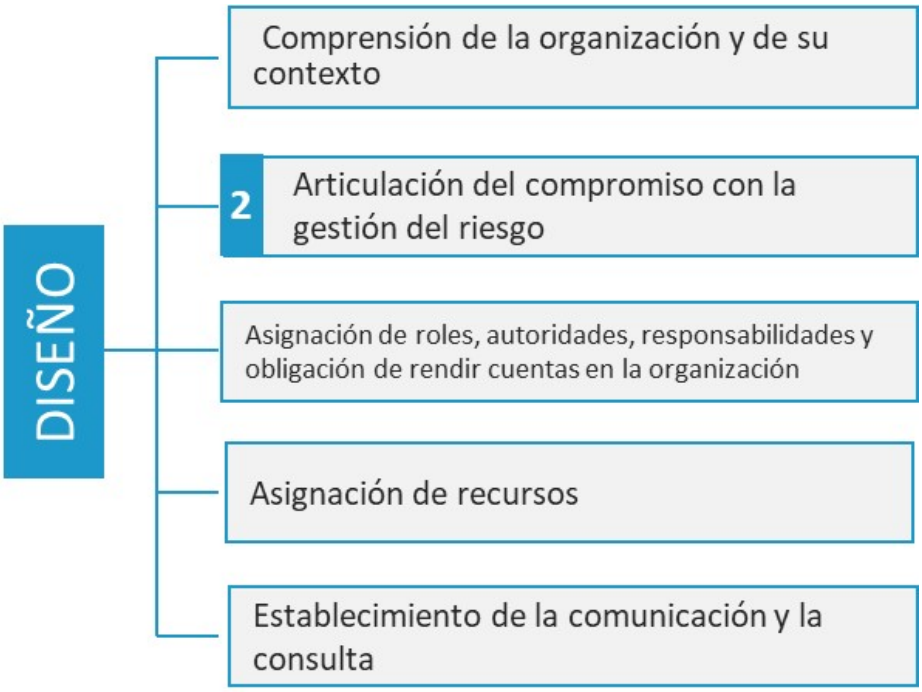


Figura 11. Articulación del compromiso con la gestión de riesgos. Fuente: elaboración propia.

La alta dirección y los organismos de supervisión, cuando sea aplicable, deberían articular y demostrar su **compromiso continuo** con la gestión de riesgos mediante una política, una declaración u otras formas que expresen claramente los objetivos y el compromiso de la organización con la gestión de riesgos.

© Universidad Internacional de La Rioja (UNIR)

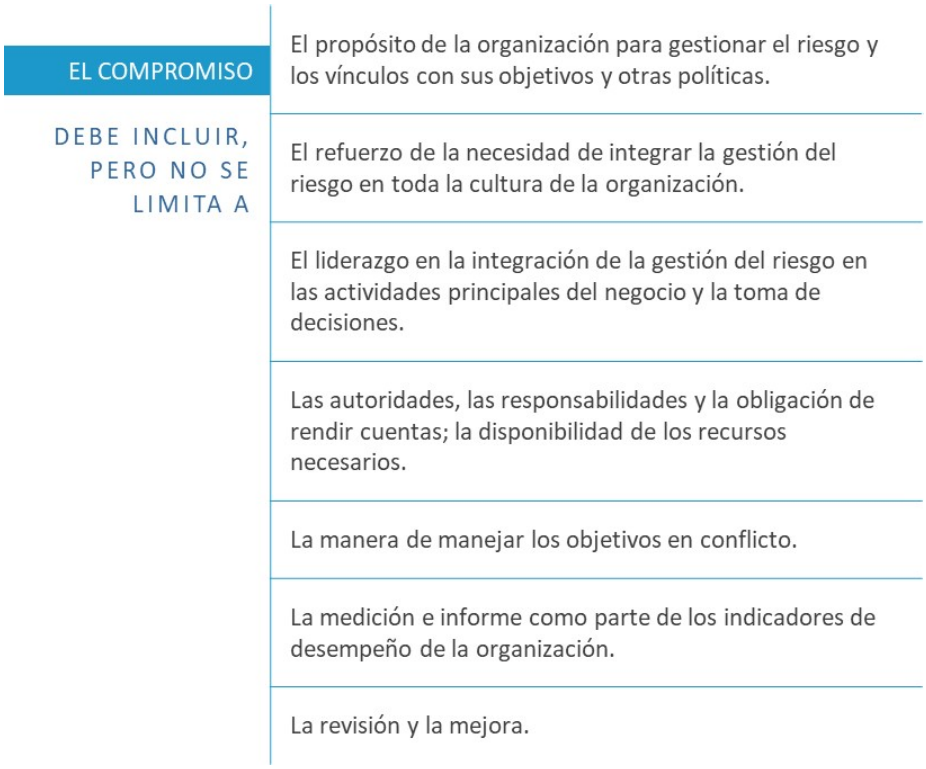


Figura 12. Objetos que incluye el compromiso. Fuente: elaboración propia.

El compromiso con la gestión de riesgos se debería comunicar dentro de la organización y a las partes interesadas, de manera apropiada.

Asignación de roles, autoridades, responsabilidades y obligación de rendir cuentas en la organización

© Universidad Internacional de La Rioja (UNIR)

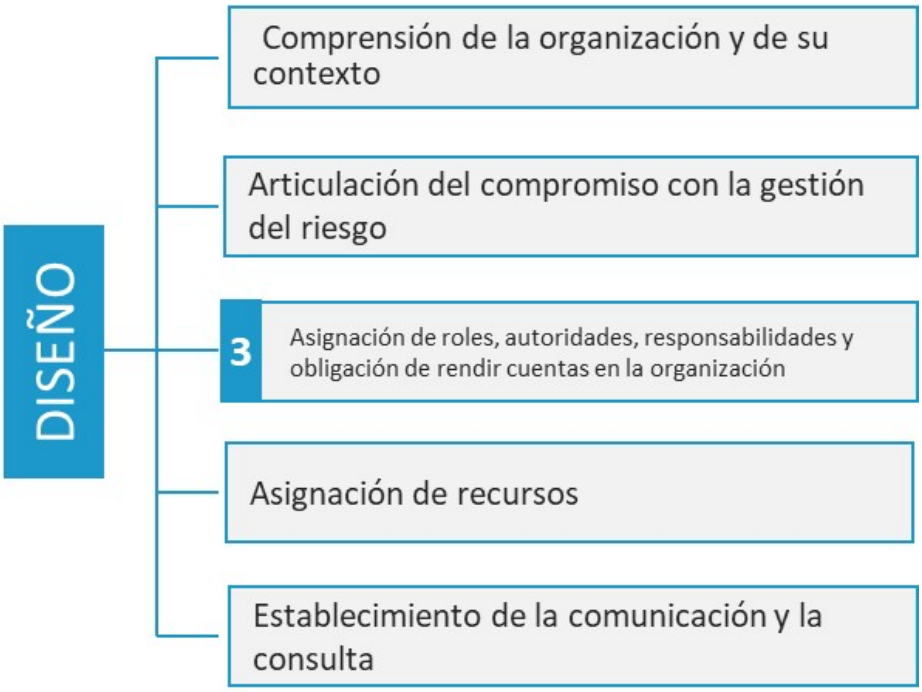


Figura 13. Asignación de roles, autoridades, responsabilidades y obligación de rendir cuentas en la organización. Fuente: elaboración propia.

La alta dirección y los órganos de supervisión, cuando sea aplicable, deberían asegurarse de que las autoridades, las responsabilidades y la obligación de rendir cuentas de **los roles relevantes con respecto a la gestión de riesgos se asignen y comuniquen a todos los niveles de la organización,** enfatizando que la gestión de riesgos es una responsabilidad principal e identificando a las personas que tienen asignada la obligación de rendir cuentas y la autoridad para gestionar el riesgo **(dueños del riesgo).**

© Universidad Internacional de La Rioja (UNIR)

Asignación de recursos

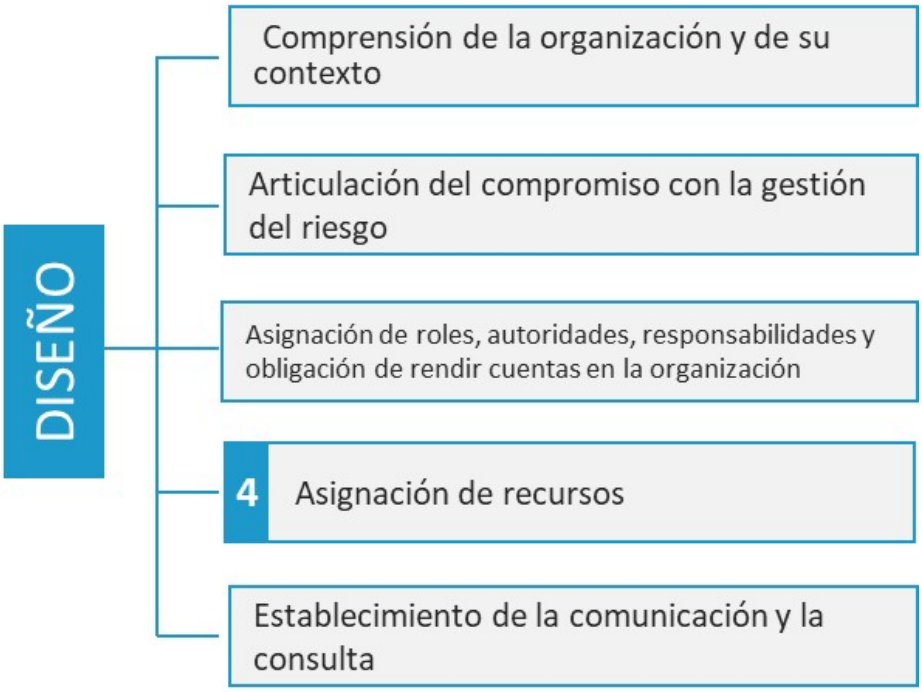


Figura 14. Asignación de recursos. Fuente: elaboración propia.

La alta dirección y los órganos de supervisión, cuando sea aplicable, deberían asegurar la asignación de los recursos apropiados para la gestión de riesgos, que puede incluir, pero no limitarse a:

- Las personas, las habilidades, la experiencia y las competencias.
- Los procesos, los métodos y las herramientas de la organización a utilizar para gestionar el riesgo.
- Los procesos y procedimientos documentados.
- Los sistemas de gestión de la información y del conocimiento.
- El desarrollo profesional y las necesidades de formación.

© Universidad Internacional de La Rioja (UNIR)

La organización debería considerar las competencias y limitaciones de los recursos existentes.

Establecimiento de la comunicación y la consulta

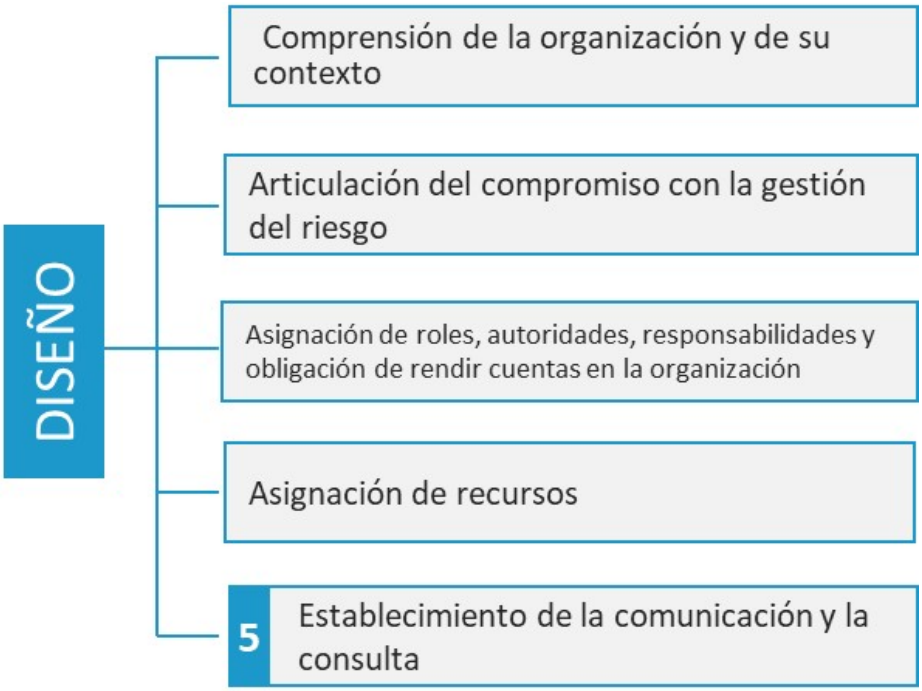


Figura 15. Establecimiento de la comunicación y la consulta. Fuente: elaboración propia.

La organización debería establecer un enfoque aprobado con relación a la comunicación y la consulta, para apoyar el marco de referencia y facilitar la aplicación eficaz de la gestión de riesgos.

La **comunicación** implica compartir información con el público objetivo. La **consulta,** además, implica que los participantes proporcionen **retroalimentación** con la expectativa de que esta contribuya y dé forma a las decisiones u otras actividades. Los métodos y el contenido de la comunicación y la consulta deberían reflejar las expectativas de las partes interesadas, cuando sea pertinente.

© Universidad Internacional de La Rioja (UNIR)

Ambas deberían ser oportunas y asegurar que se **recopile, consolide, sintetice y comparta la información** pertinente, cuando sea apropiado, y que se proporcione retroalimentación y se lleven a cabo mejoras.

Implementación



Figura 16. Implementación. Fuente: adaptado de UNE-ISO 31000:2018 (2018), p. 11.

La organización debería implementar el marco de referencia de la gestión de riesgos mediante:

- El desarrollo de un plan apropiado incluyendo plazos y recursos.}
- La identificación de dónde, cuándo, cómo y quién toma diferentes tipos de decisiones en toda la organización.
- La modificación de los procesos aplicables para la toma de decisiones, cuando sea necesario.
- El aseguramiento de que las disposiciones de la organización para gestionar el

© Universidad Internacional de La Rioja (UNIR)

riesgo son claramente comprendidas y puestas en práctica.

La implementación con éxito del marco de referencia requiere el compromiso y la toma de conciencia de las partes interesadas. Esto permite a las organizaciones abordar explícitamente la incertidumbre en la toma de decisiones, al tiempo que asegura que cualquier incertidumbre nueva o subsiguiente se pueda tener en cuenta cuando surja.

Si se diseña e implementa correctamente, el marco de referencia de la gestión de riesgos asegurará que el proceso de la gestión de riesgos sea parte de todas actividades en toda la organización, incluyendo la toma de decisiones y que los cambios en los contextos externo e interno se captarán de manera adecuada.

Valoración

© Universidad Internacional de La Rioja (UNIR)



Figura 17. Valoración. Fuente: adaptado de UNE-ISO 31000:2018 (2018), p. 11.

Una organización, para poder valorar la eficacia y eficiencia del marco de referencia de la gestión de riesgos, debe implantar métricas y mecanismos que le permitan medir periódicamente su desempeño en relación con el propósito de este y valorando su comportamiento respecto a lo esperado para determinar si el diseño y la implementación del marco de trabajo siguen siendo idóneos para dar soporte al cumplimiento de los objetivos de la organización.

Mejora

© Universidad Internacional de La Rioja (UNIR)



Figura 18. Mejora. Fuente: adaptado de UNE-ISO 31000:2018 (2018), p. 11.

Una organización debe llevar a cabo un seguimiento continuo del proceso de gestión de riesgos y adaptar el marco de referencia de la gestión de riesgos en función de los cambios de los contextos externo e interno de la organización. Esta adaptación permite a la organización incrementar su valor.

Con esta mejora continua, se persigue mantener y, si es posible, incrementar la eficacia, la eficiencia, la idoneidad y la adecuación del marco de referencia de la gestión de riesgos a las necesidades de la organización, así como la integración del proceso de la gestión de riesgos en la misma.

Cuando se identifiquen brechas u oportunidades de mejora pertinentes, la organización debería desarrollar planes y tareas y asignarlas a quienes tuviesen que rendir cuentas de su implementación. Una vez realizadas, estas mejoras deberían

© Universidad Internacional de La Rioja (UNIR)

contribuir al fortalecimiento de la gestión de riesgos.

© Universidad Internacional de La Rioja (UNIR)

7.5. Proceso de la UNE-ISO 31000:2018

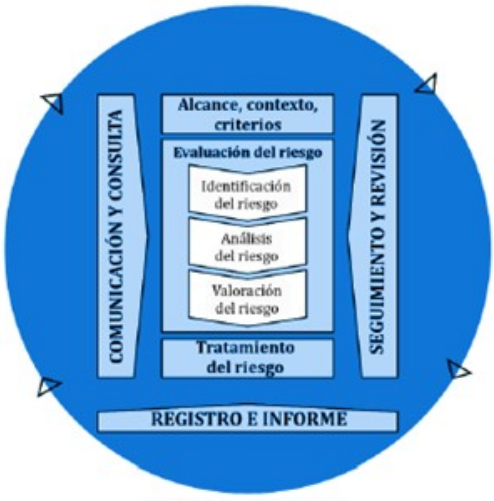


Figura 19. Proceso. Fuente: UNE-ISO 31000:2018 (2018), p. 16.

El proceso de la gestión de riesgos implica la aplicación sistemática de políticas, procedimientos y prácticas a las actividades de comunicación y consulta, establecimiento del contexto y evaluación, tratamiento, seguimiento, revisión y, finalmente, registro e informe del riesgo.

También debe formar parte integral de la **gestión de la organización y de la toma de decisiones,** para ello se debe integrar en la cultura, en sus prácticas y procedimientos y adaptarse a los procesos de negocio.

Los **procesos de la gestión de riesgos** pueden aplicarse a nivel estratégico, operacional, de programa o de proyecto y pueden darse diferentes aplicaciones o instancias de dichos procesos dentro de una organización, adaptadas cada una de ellas para el logro de los objetivos concretos. También deberán ser apropiadas a los contextos externo e interno en los cuales se aplican.

A lo largo del proceso se debería considerar la **naturaleza dinámica y variable del comportamiento humano** y de los factores culturales. Y aunque se presenta

© Universidad Internacional de La Rioja (UNIR)

frecuentemente como secuencial, en la práctica es **iterativo.**

Comunicación y consulta

El propósito de la comunicación y consulta es **asistir a las partes interesadas** pertinentes a **comprender** el **riesgo,** las bases con las que se toman **decisiones** y las razones por las que son necesarias acciones específicas. La c**omunicación** busca promover la toma de conciencia y la comprensión del riesgo, mientras que la **consulta** implica obtener retroalimentación e información para apoyar la toma de decisiones. Una coordinación cercana entre ambas debería facilitar un **intercambio de información basado en hechos,** oportuno, pertinente, exacto y comprensible, teniendo en cuenta la confidencialidad e integridad de la información, así como el derecho a la privacidad de las personas.

La comunicación y consulta con las partes interesadas apropiadas, externas e internas, se debería realizar en todas y cada una de las etapas del proceso de la gestión de riesgos.

La comunicación y consulta pretende:

- Reunir diferentes áreas de experiencia para cada etapa del proceso de la gestión de riesgos.
- Asegurar que se consideren de manera apropiada los diferentes puntos de vista cuando se definen los criterios del riesgo y cuando se valoran los riesgos.
- Proporcionar suficiente información para facilitar la supervisión del riesgo y la toma de decisiones.
- Construir un sentido de inclusión y propiedad entre las personas afectadas por el

© Universidad Internacional de La Rioja (UNIR)

riesgo.

Las **comunicaciones** y las **consultas** con las partes interesadas externas e internas se deberían realizar en todas las etapas del proceso de gestión de riesgos.

Por ello, en una de las primeras etapas se deberán desarrollar los **planes de comunicación y consulta.** Estos planes deberán tratar temas relativos al riesgo en sí mismo, a sus causas, a sus consecuencias (si se conocen) y a las medidas a tomar para tratarlo.

Se deberán realizar comunicaciones y consultas externas e internas eficaces para asegurarse de que las **personas responsables** de la implementación del proceso de gestión de riesgos y las partes interesadas comprenden las bases que han servido para tomar decisiones y las razones por las que son necesarias determinadas acciones.

Un **enfoque consultivo** en equipo puede ayudar a:

- Establecer adecuadamente el contexto.
- Asegurar que los intereses de las partes interesadas se comprenden y se tienen en consideración.
- Asegurar que los riesgos se identifican adecuadamente.
- Reunir diferentes áreas de experiencia para analizar los riesgos.
- Tener en cuenta las diferentes opiniones de forma adecuada, al definir los criterios de riesgo y en la valoración de los riesgos.
- Conseguir la aprobación y el apoyo para un plan de tratamiento.
- Favorecer una gestión del cambio adecuada durante el proceso de gestión de riesgos.

© Universidad Internacional de La Rioja (UNIR)

- Desarrollar un plan adecuado de comunicación y consultas externas e internas.

Las comunicaciones y consultas con las partes interesadas son importantes ya que estas pueden emitir juicios sobre el riego basados en sus **percepciones de riesgo.** Estas percepciones pueden variar debido a diferencias en los valores, las necesidades, las hipótesis, los conceptos y las inquietudes de las partes interesadas. Como sus opiniones pueden tener un impacto importante en las decisiones a tomar, las percepciones de las partes interesadas se deberían identificar, registrar y tomar en consideración en el proceso de **toma de decisiones.**

Las actividades de comunicación y consulta deben facilitar intercambios de información que sean veraces, pertinentes, exactos y entendibles, teniendo en cuenta los aspectos de la confidencialidad y la integridad de las personas.

Alcance, contexto y criterios

El propósito del establecimiento del alcance, contexto y criterios es adaptar el proceso de la gestión de riesgos, para permitir una evaluación del riesgo eficaz y un tratamiento apropiado del riesgo. El alcance, el contexto y los criterios implican definir el alcance del proceso y comprender los contextos externo e interno.

Definición del alcance

La organización debería definir el alcance de sus actividades de gestión de riesgos.

Como el proceso de la gestión de riesgos puede aplicarse a niveles distintos (por ejemplo: estratégico, operacional, de programa, de proyecto u otras actividades), es importante tener claro el alcance considerado, los objetivos pertinentes a considerar y su alineamiento con los objetivos de la organización.

© Universidad Internacional de La Rioja (UNIR)

En la planificación del enfoque se incluyen las siguientes consideraciones:

- Los objetivos y las decisiones que se necesitan tomar.
- Los resultados esperados de las etapas a ejecutar en el proceso.
- El tiempo, la ubicación, las inclusiones y las exclusiones especificas.
- Las herramientas y las técnicas apropiadas de evaluación del riesgo.
- Los recursos requeridos, responsabilidades y registros a conservar.
- Las relaciones con otros proyectos, procesos y actividades.

Contextos externo e interno

Los contextos externo e interno son el **entorno** en el cual la organización busca definir y lograr sus objetivos.

El contexto del proceso de la gestión de riesgos se debería establecer a partir de la comprensión de los entornos externo e interno en los cuales opera la organización y debería reflejar el entorno específico de la actividad en la cual se va a aplicar el proceso de la gestión de riesgos.

La comprensión del contexto es importante porque:

- La gestión de riesgos tiene lugar en el contexto de los objetivos y las actividades de la organización.
- Los factores organizacionales pueden ser una fuente de riesgo.
- El propósito y alcance del proceso de la gestión de riesgos 8 estar interrelacionado con los objetivos de la organización como un todo.
- La organización debería establecer los contextos externo e interno del proceso de la gestión de riesgos, considerando los factores que se tuvieron en cuenta en la

© Universidad Internacional de La Rioja (UNIR)

elaboración del marco de referencia.

Mediante el establecimiento del contexto, la organización articula sus objetivos, define los parámetros externos e internos a tener en cuenta en la gestión de riesgos y establece el alcance y los **criterios de riesgo** para el proceso restante.

Aunque muchos de estos **parámetros** son similares a los considerados en el diseño del marco de referencia de la gestión de riesgos, cuando se establece el contexto para el proceso de gestión de riesgos tales parámetros se deben considerar en mayor detalle y, en particular, cómo están relacionados con el alcance del proceso de gestión de riesgos.

Establecimiento del contexto del proceso de gestión de riesgos

Se deberían establecer los objetivos, las estrategias, el alcance y los parámetros de las actividades de la organización o de aquellas partes de la organización donde se aplica el proceso de gestión de riesgos. La gestión de riesgos se debería emprender teniendo en cuenta todo lo necesario para justificar los recursos que se han de utilizar para llevarla a cabo.

También se deberían especificar los **recursos requeridos,** las **responsabilidades** y **autoridades** y los **registros** que se deben conservar.

E l **contexto del proceso de la gestión de riesgos** variará de acuerdo con las necesidades de la organización. Puede implicar, pero **no se limita a:**

- La definición de las metas y objetivos de las actividades de gestión de riesgos.
- La definición de las responsabilidades relativas al proceso de gestión de riesgos.
- La definición del alcance, así como el grado y la amplitud de las actividades de gestión de riesgos a realizar, definiendo las inclusiones y exclusiones específicas.
- La definición de la actividad, del proceso, de la función, del proyecto, del producto,

© Universidad Internacional de La Rioja (UNIR)

del servicio o del activo, en términos de tiempo y de ubicación.

- La definición de las relaciones entre un proyecto, un proceso o una actividad particular y otros proyectos, procesos o actividades de la organización.
- La definición de las metodologías de evaluación del riesgo.
- La definición del método para evaluar el desempeño y la eficacia en la gestión de riesgos.
- La identificación y la especificación de las decisiones a tomar.
- La identificación, el alcance o el marco de los estudios requeridos, su amplitud y sus objetivos, así como los recursos necesarios para tales estudios.

Se deberían tener en cuenta estos y otros factores pertinentes para asegurar que el enfoque adoptado de la gestión de riesgos es apropiado a las circunstancias, a la organización y a los riesgos que afectan al logro de sus objetivos.

Definición de los criterios de riesgo

La organización debería definir los criterios que se aplican para evaluar la importancia del riesgo, estableciendo su apetito al riesgo, en relación con los objetivos de la organización, el nivel y tipo de riesgo que está dispuesta a asumir.

Los criterios deberían reflejar los valores, los objetivos y los recursos de la organización. Algunos criterios pueden estar impuestos, derivarse de requisitos legales o reglamentarios o de otros requisitos suscritos por la organización y deben tener en cuenta los puntos de vista de las partes interesadas. Los criterios de riesgo deberían ser coherentes con la política de gestión de riesgos de la organización, definirse al comienzo de cualquier proceso de gestión de riesgos y revisarse continuamente.

Los criterios del riesgo se deberían alinear con el marco de referencia de la gestión

© Universidad Internacional de La Rioja (UNIR)

de riesgos y adaptar al propósito y al alcance específicos de la actividad considerada.

Al definir los criterios de riesgo, se deberían considerar una serie de factores entre los cuales se incluyen los siguientes:

- La naturaleza y los tipos de riesgos que pueden afectar a los resultados y objetivos, tanto tangibles como intangibles.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Las consecuencias, tanto positivas como negativas, que se pueden producir y cómo se deben medir.
- El método de definición de la probabilidad.
- Los plazos de la probabilidad y/o de las consecuencias.
- El método para determinar el nivel de riesgo.
- La coherencia en el uso de los tipos de mediciones.
- Las opiniones de las partes interesadas.
- El nivel en el que el riesgo comienza a ser aceptable o tolerable.
- Si se deberían tener en cuenta combinaciones de riesgos múltiples y, en caso afirmativo, cómo y qué combinaciones se deberían considerar.
- La capacidad de la organización

Evaluación del riesgo

La evaluación del riesgo es el **proceso global** de identificación, de análisis y de valoración del riesgo.

La evaluación del riesgo se debería llevar a cabo de manera sistemática, iterativa y colaborativa, basándose en el conocimiento y los puntos de vista de las partes interesadas. Se debería utilizar la mejor información disponible, complementada por investigación adicional, si fuese necesario.

© Universidad Internacional de La Rioja (UNIR)

Identificación del riesgo

El propósito de la identificación del riesgo es encontrar, reconocer y describir los riesgos que pueden ayudar o impedir a una organización lograr sus objetivos.

La organización debería identificar los **orígenes** de riesgo, las **áreas de impacto,** los **sucesos** (incluyendo los cambios de circunstancias), así como sus causas y sus consecuencias potenciales.

El objetivo de esta etapa consiste en generar una lista de riesgos exhaustiva basada en aquellos sucesos que podrían crear, mejorar, prevenir, degradar, acelerar o retrasar el logro de los objetivos. Es importante identificar los riesgos asociados al hecho de no **buscar una oportunidad.** Es esencial realizar una identificación exhaustiva, ya que un riesgo que no se identifica en esta etapa no se incluirá en análisis posteriores.

La identificación debería incluir los riesgos, tanto si su origen está o no **bajo el control de la organización,** incluso aunque el origen o la causa del riesgo no pueda ser evidente. También debería incluir el examen de los efectos en cadena de **consecuencias** particulares, incluyendo los efectos en cascada o acumulativos. Finalmente, debería considerar un amplio rango de consecuencias, incluso aunque el origen o la causa del riesgo no puedan ser evidentes. Además de identificar lo que podría ocurrir, es necesario considerar las posibles **causas** y escenarios que muestran las consecuencias que se pueden producir. Todas las causas y consecuencias significativas se deberían tener en consideración.

La organización debería aplicar **herramientas y técnicas de identificación del riesgo** que se adapten a sus objetivos y aptitudes, así como a los riesgos a los que está expuesta. Para la identificación de los riesgos es esencial disponer de información pertinente y actualizada. Siempre que sea posible, esta información debería ir acompañada de antecedentes apropiados. En la identificación de los

© Universidad Internacional de La Rioja (UNIR)

riesgos deberían intervenir personas con conocimientos apropiados.

© Universidad Internacional de La Rioja (UNIR)

Para la identificación del riesgo se deberían considerar los siguientes factores y la relación entre ellos:

- Las fuentes del riesgo, tanto tangibles como intangibles.
- Los eventos y sus causas.
- Las oportunidades y las amenazas.
- Las vulnerabilidades y las capacidades.
- Los cambios en los contextos interno y externo.
- Los indicadores de riesgos emergentes.
- El valor y la naturaleza de los activos y de los recursos.
- Las consecuencias y sus impactos en los objetivos de la organización.
- Las limitaciones de la información disponible, tanto de conocimiento como de confiabilidad.
- Los factores temporales.
- Las percepciones, las creencias, los supuestos y los sesgos de las personas involucradas.

Análisis del riesgo

El propósito del análisis del riesgo es comprender la naturaleza del riesgo y sus características, incluyendo (cuando sea apropiado) el nivel del riesgo. Este análisis del riesgo conlleva un estudio detallado que tenga en consideración las incertidumbres, las fuentes de riesgo, las consecuencias, las probabilidades de ocurrencia de los eventos, de los escenarios, los controles implantados y su eficacia.

El análisis del riesgo implica desarrollar una **comprensión del riesgo.** Además,

© Universidad Internacional de La Rioja (UNIR)

proporciona elementos de entrada para la valoración del riesgo y para tomar decisiones acerca de si es necesario tratar los riesgos, así como las estrategias y los métodos de **tratamiento del riesgo** más apropiados. También puede proporcionar elementos de entrada para tomar decisiones cuando se deben hacer elecciones y las opciones implican diferentes tipos de niveles de riesgo.

El análisis del riesgo implica la consideración de las causas y las **fuentes del riesgo,** sus **consecuencias,** positivas y negativas, y la probabilidad de que estas consecuencias puedan ocurrir. Se deberían identificar los factores que afectan a las consecuencias y a la **probabilidad.** El riesgo se analiza determinando las consecuencias y su probabilidad, así como otros atributos del riesgo. Un suceso puede tener múltiples consecuencias y puede afectar a múltiples objetivos. También se deberían tener en cuenta los controles existentes, así como su eficacia y su eficiencia.

El análisis del riesgo debería considerar factores tales como:

- Las consecuencias de los eventos y la probabilidad de su ocurrencia
- La magnitud y naturaleza de las consecuencias.
- Las interrelaciones y su complejidad.
- Los factores temporales y la volatilidad.
- La eficacia de los controles existentes.
- Los niveles de confianza y sensibilidad.

La forma de expresar las consecuencias y la probabilidad, así como la manera en que estas se combinan para determinar un nivel de riesgo, debería corresponder al tipo de riesgo, a la información disponible y al objetivo para el que se utiliza el resultado de la evaluación del riesgo. Todos estos datos deberían ser coherentes con los **criterios de riesgo.** También es importante considerar la interdependencia de los

© Universidad Internacional de La Rioja (UNIR)

diferentes riesgos y de sus fuentes.

La confianza en la determinación del **nivel de riesgo** y su sensibilidad a las condiciones previas y a las hipótesis se debería considerar en el análisis y comunicar de manera eficaz a las personas que han de tornar decisiones y, cuando corresponda, a otras partes interesadas. Factores tales como las diferencias de opinión entre expertos, la incertidumbre, la disponibilidad, la calidad, la cantidad y la validez de la pertinencia de la información, o las limitaciones respecto a modelos establecidos, se deberían indicar y pueden resaltarse.

El análisis del riesgo se puede realizar con **diferentes grados de detalle,** dependiendo del riesgo, de la finalidad del análisis y de la información disponible y confiabilidad, así como de los datos y los recursos disponibles. Las técnicas de análisis empleadas pueden ser cualitativas, semi-cuantitativas, cuantitativas o una combinación de las estas, dependiendo de las circunstancias y del uso previsto.

Las consecuencias y su probabilidad se pueden determinar realizando el **modelo de los resultados de un suceso** o conjunto de sucesos o por la extrapolación de estudios experimentales o de datos disponibles. Las consecuencias se pueden expresar en términos de impactos tangibles o intangibles. En algunos casos, se requiere más de un valor numérico o descriptor para especificar las consecuencias y su probabilidad para diferentes momentos, lugares, grupos o situaciones.

El análisis del riesgo puede estar influenciado por cualquier divergencia de opiniones, sesgos, percepciones del riesgo y juicios. Las influencias adicionales son la calidad de la información utilizada, los supuestos y las exclusiones establecidas, cualquier limitación de las técnicas y cómo se ejecutan estas. Estas influencias se deberían considerar, documentar y comunicar a las personas que toman decisiones.

Los eventos de alta incertidumbre pueden ser difíciles de cuantificar. Esto puede ser una cuestión importante cuando se analizan eventos con consecuencias severas. En

© Universidad Internacional de La Rioja (UNIR)

tales casos, el uso de una combinación de técnicas generalmente proporciona una visión más amplia.

El análisis del riesgo proporciona una entrada para la valoración del riesgo, para las decisiones sobre la manera de tratar los riesgos, y si es necesario hacerlo, y sobre la estrategia y los métodos más apropiados de tratamiento del riesgo. Los resultados proporcionan un entendimiento profundo para tomar decisiones cuando se está eligiendo entre distintas alternativas y las opciones implican diferentes tipos y niveles de riesgo.

Valoración del riesgo

El propósito de la valoración del riesgo es ayudar a la **toma de decisiones.** Implica comparar el nivel de riesgo obtenido como resultado del proceso de análisis del riesgo con los criterios establecidos.

En base a esta comparación, se puede tomar la decisión de:

- No tomar ninguna acción más.
- Considerar opciones para el tratamiento del riesgo
- Realizar un análisis adicional para comprender mejor el riesgo
- Mantener los controles existentes.
- Reconsiderar los objetivos.

Para las decisiones se debería tener en cuenta el contexto más amplio del riesgo e incluir la consideración de la **tolerancia del riesgo** por otras partes diferentes de la organización, que se benefician del riesgo. Las decisiones se deberían tomar de acuerdo con requisitos legales, reglamentarios y requisitos de otro tipo.

En algunas circunstancias, la valoración del riesgo puede llevar a la decisión de realizar un **análisis en mayor profundidad.**

© Universidad Internacional de La Rioja (UNIR)

La valoración del riesgo también puede llevar a la decisión de no tratar el riesgo de ninguna otra manera que manteniendo los **controles** existentes. Esta decisión estará influenciada por la actitud ante el riesgo por parte de la organización y por los criterios de riesgo que se hayan establecido.

Tratamiento del riesgo

El tratamiento del riesgo implica la selección y la implementación de una o varias opciones para **modificar los riesgos.**

Una vez realizada la **implementación,** los tratamientos proporcionan o modifican los controles.

El tratamiento del riesgo supone un **proceso cíclico** de:

- Formular y seleccionar opciones para el tratamiento del riesgo.
- Planificar e implementar el tratamiento del riesgo.
- Evaluar la eficacia del tratamiento del riesgo.
- Decidir si los niveles de riesgo residual son tolerables.
- Si no son tolerables, efectuar un tratamiento del riesgo adicional.

Selección de opciones de tratamiento del riesgo

La selección de las opciones más apropiada de **tratamiento del riesgo** implica efectuar un balance entre los beneficios potenciales, derivados del logro de los objetivos contra los costes y los esfuerzos de implementación en función de las ventajas que se obtengan, teniendo en cuenta los requisitos legales, reglamentarios

© Universidad Internacional de La Rioja (UNIR)

y de otro tipo, tales como la responsabilidad social y la protección del entorno natural. Las decisiones también se deberían tomar teniendo en cuenta los riesgos cuyo tratamiento no es justificable en el plano económico, por ejemplo**, riesgos severos** (consecuencias altamente negativas) pero raros (baja probabilidad).

Las **opciones de tratamiento** del riesgo no se excluyen necesariamente unas a otras, ni son apropiadas en todas las circunstancias.

Las **opciones** pueden incluir lo siguiente:

- **Evitar** el riesgo decidiendo no iniciar o continuar con la actividad que causa el riesgo.
- **Aceptar o aumentar** el riesgo a fin de perseguir una oportunidad.
- **Eliminar** la fuente del riesgo.
- **Modificar** la probabilidad.
- **Modificar** las consecuencias.
- **Compartir** el riesgo con otras partes (incluyendo los contratos y la financiación del riesgo).
- **Retener** el riesgo en base a una decisión informada.

Un determinado número de **opciones de tratamiento** se puede considerar y aplicar individualmente o bien en combinación.

Normalmente, la organización puede beneficiarse de la adopción de una **combinación de opciones de tratamiento.**

La justificación del tratamiento del riesgo debe ser más amplia que unas simples consideraciones de carácter económico y debería tener en cuenta todas las obligaciones de la organización, los compromisos voluntarios y los puntos de vista de

© Universidad Internacional de La Rioja (UNIR)

las partes interesadas. La selección de las opciones para el tratamiento del riesgo debería realizarse de acuerdo con los objetivos de la organización, los criterios del riesgo y los recursos disponibles.

Al seleccionar opciones de tratamiento del riesgo, la organización debería tener en consideración los valores y las percepciones de las partes interesadas y los medios más apropiados para comunicarse con ellas. Cuando las opciones de tratamiento del riesgo puedan impactar sobre el riesgo en cualquier otra parte de la organización o en las partes interesadas, estas se deberían involucrar en la decisión. A igual eficacia, algunos tratamientos del riesgo pueden ser más aceptables que otros para algunas partes interesadas.

Los tratamientos del riesgo, a pesar de un cuidadoso diseño e implementación, pueden no producir los resultados esperados y pueden producir consecuencias no previstas, es decir, nuevos riesgos.

El tratamiento del riesgo también puede introducir **riesgos secundarios** que necesitan que se aprecien, se traten, se realice seguimiento y se revisen. Estos riesgos secundarios se deberían incorporar en el mismo plan de tratamiento que el riesgo original y no tratarse como riesgos nuevos. La relación entre los dos riesgos debería identificarse y mantenerse.

El fallo o la ineficacia de las medidas de tratamiento del riesgo pueden constituir un riesgo importante, por ello el seguimiento y la revisión necesitan ser parte integral de la implementación del tratamiento del riesgo para asegurar que las distintas formas del tratamiento sean eficaces y conserven dicha eficacia a lo largo del tiempo.

Si no hay opciones disponibles para el tratamiento o si las opciones para el tratamiento no modifican suficientemente el riesgo, este se debería registrar y mantener en continua revisión.

Las personas que toman decisiones y otras partes interesadas deberían ser

© Universidad Internacional de La Rioja (UNIR)

conscientes de la naturaleza y el nivel de riesgo residual después del tratamiento del riesgo. El riesgo residual se debería documentar y ser objeto de seguimiento, revisión y, cuando sea apropiado, de tratamiento adicional.

Preparación e implementación de los planes de tratamiento del riesgo

La **finalidad** de los planes de tratamiento del riesgo consiste en documentar la manera en que se implantarán las opciones de tratamiento elegidas, de tal forma que las personas involucradas comprendan las acciones que se van a tomar y pueda realizarse el seguimiento del avance del plan respecto a lo planificado.

El plan de tratamiento del riesgo debería identificar claramente la prioridad en la implementación de los diferentes tratamientos individuales.

La información proporcionada en los **planes de tratamiento** debería incluir lo siguiente:

- Las razones que justifican la selección de las opciones de tratamiento, incluyendo los beneficios previstos.
- Las personas responsables de la aprobación del plan y las personas responsables de la implementación del plan.
- Las acciones propuestas.
- Las necesidades de recursos, incluyendo las contingencias.
- Las medidas del desempeño y las restricciones.
- Los requisitos en materia de información y de seguimiento.
- El calendario y la programación.

Los **planes de tratamiento** deberían integrarse en los procesos de gestión de la organización y discutirse con las partes interesadas apropiadas.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El avance en la **implantación de los planes de tratamiento del riesgo** proporciona una medida del funcionamiento.

Las personas que toman decisiones y las otras partes interesadas deberían estar enteradas de la **naturaleza y amplitud del riesgo residual** después del tratamiento del riesgo. El riesgo residual se debería documentar y someter a seguimiento, revisión y, cuando sea apropiado, a tratamiento adicional.

Seguimiento y revisión

El propósito del seguimiento y la revisión es asegurar y mejorar la calidad y la eficacia del diseño, la implementación y los resultados del proceso.

El seguimiento continuo y la revisión periódica deberían planificarse en el proceso de tratamiento del riesgo y someterse a una verificación o una **vigilancia** regular. Esta verificación o vigilancia puede ser periódica o eventual.

Las **responsabilidades** del seguimiento y de la **revisión** deberían estar claramente definidas.

El seguimiento y la revisión deberían tener lugar en todas las etapas del proceso de gestión de riesgos. Las actividades de seguimiento y revisión incluyen planificar, recopilar y analizar información, registrar resultados y proporcionar retroalimentación.

Los procesos de seguimiento y de revisión de la organización deberían abarcar todos los aspectos del proceso de gestión de riesgos, con la **finalidad** de:

- Asegurar que los controles son eficaces y eficientes tanto en su diseño como en su utilización.
- Obtener la información adicional para mejorar la evaluación del riesgo.

© Universidad Internacional de La Rioja (UNIR)

- Analizar y sacar conclusiones de los sucesos, cambios, tendencias, éxitos y fallos.
- Detectar los cambios en el contexto interno y externo, incluidos los cambios en los criterios de riesgo y en el propio riesgo, que puedan requerir la revisión de los tratamientos de riesgo y de las prioridades.
- Identificar los riesgos emergentes.

Los resultados del seguimiento y revisión se deberían incorporar a todas las actividades de gestión del funcionamiento global de la organización y a su medición.

Los resultados del seguimiento y de la revisión se deberían registrar e incluir en informes internos y externos, según sea apropiado, y también se deberían utilizar como elementos de entrada para la **revisión del marco de referencia** de la gestión de riesgos.

Registro e informe del proceso de gestión de riesgos

Las **actividades de gestión de riesgos** deberían ser trazables. En el proceso de gestión de riesgos los registros y los informes proporcionan la base para la mejora de los métodos y de las herramientas, así como del proceso en su conjunto.

Los registros y los informes tienen por objeto comunicar las actividades de la gestión de riesgos y sus resultados a toda la organización, proporcionando la información necesaria para la toma de decisiones, para la mejora de las partes interesadas, especialmente a aquellas que tienen la responsabilidad y la obligación de rendir cuentas de las actividades de la gestión de riesgos.

Las decisiones relativas a la **creación de registros** deberían tener en cuenta:

- Las necesidades de la organización en materia de aprendizaje continuo.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Los beneficios de reutilizar la información para fines de gestión.
- Los costes y los esfuerzos que suponen la creación y el mantenimiento de los registros.
- Las necesidades legales, reglamentarias y operacionales para efectuar los registros.
- El método de acceso, la facilidad de recuperación y los medios de almacenaje.
- El período de conservación.
- El carácter sensible de la información.
- El contexto de la organización.

La elaboración de informes forma parte integral de la gobernanza de la organización. Los informes deben mejorar la calidad del diálogo con las partes interesadas y apoyar a la alta dirección y a los órganos de supervisión a cumplir con sus responsabilidades.

Entre los factores a considerar a la hora de elaborar los informes se incluyen, pero no se limitan a:

- Las necesidades y requisitos específicos de información de las partes interesadas.
- El momento, la frecuencia y el coste de elaboración de los informes.
- Los métodos de elaboración y comunicación.
- La pertinencia de la información que se incluye en los mismos con respecto a los objetivos de la organización y la toma de decisiones.

© Universidad Internacional de La Rioja (UNIR)

7.6. Referencias bibliográficas

Normalización Española. (2018). Gestión del riesgo. Directrices (estándar ISO 3 1 0 0 0 : 2 0 1 8) . https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0059900

Normalización Española. (2011). Gestión del riesgo. Técnicas de apreciación del riego (estándar EN 31010:2011). https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0047287

Normalización Española. (2005). Gestión del riesgo. Vocabulario. Directrices para la utilización en las normas. (estándar ISO/IEC 73:2005 IN, anulada). https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0035180

© Universidad Internacional de La Rioja (UNIR)

Modelo basado en metodologías de gestión de riesgos de ti para contribuir en la mejora de la seguridad de los activos de información

Banda Santisteban, J. C. (2019). *Modelo basado en metodologías de gestión de riesgos de TI para contribuir en la mejora de la seguridad de los activos de información en empresas del sector agroindustrial de la región Lambayeque* [tesis de maestría, Universidad Católica Santo Toribio de Mongrovejo]. Repositorio de Tesis USAT. http://hdl.handle.net/20.500.12423/2159

La presente investigación brinda una propuesta de solución frente a los escenarios de riesgo a los que se encuentran expuestos los activos de información. Para ello, se ha realizado el análisis de conceptos, estándares y metodologías relacionados con la gestión de riesgos, los mismos que al ser adaptados al contexto de las empresas agroindustriales proporcionan las guías necesarias para reducir el nivel de riesgo.

Banda Santisteban, J. C. (2019). *Modelo basado en metodologías de gestión de riesgos de TI para contribuir en la mejora de la seguridad de los activos de información en empresas del sector agroindustrial de la región Lambayeque* [tesis de maestría, Universidad Católica Santo Toribio de Mongrovejo]. Repositorio de Tesis USAT. http://hdl.handle.net/20.500.12423/2159

© Universidad Internacional de La Rioja (UNIR)

Ciberamenazas y Tendencias. Edición 2021

Centro Criptológico Nacional. (2021). *Ciber_Amenazas y tendencias. CCN-CERT IA-13/21. Edición 2021.* Centro Criptológico Nacional. https://www.ccn-cert.cni.es/informes/informes-ccn-cert-publicos/6338-ccn-cert-ia-13-21-ciberamenazas-y-tendencias-edicion-2021-1/file.html

Este informe detalla las principales amenazas y métodos de ataque registrados el pasado año. También repasamos las principales vulnerabilidades encontradas y los incidentes de mayor repercusión, tanto en términos de ciberespionaje o ingeniería social, como respecto a intrusiones en sectores que hasta el momento no habían sido un objetivo destacado.

© Universidad Internacional de La Rioja (UNIR)

Gestión de Riesgo. Una guía de aproximación para el empresario

INCIBE. (2015). *Gestión de riesgos: una guía de aproximación para el empresario.* INCIBE. https://www.incibe.es/protege-tu-empresa/guias/gestion-riesgos-guia-empresario

Las decisiones de seguridad de la información son en realidad decisiones de gestión de riesgos. En esta guía, publicada por INCIBE, se introducen los conceptos y procesos comunes a toda actividad de gestión de riesgos y muestra la aplicación de estos conceptos y procesos a la seguridad de la información.

© Universidad Internacional de La Rioja (UNIR)

Análisis de riesgos dinámicos en sistemas de información

López Cuenca, D. (2012). Análisis de riesgos dinámicos en sistemas de información [proyecto de maestría, Universidad Complutense de Madrid]. Repertorio Institucional de la UCM. https://eprints.ucm.es/id/eprint/16931/

Este trabajo de David López Cuenca hace un recorrido por las principales corrientes que buscan sacar partido a este potencial, englobadas principalmente bajo el concepto de Análisis de Riesgos Dinámico, cuyo principio es la actualización incesante de los parámetros que intervienen en el cálculo del riesgo para la optimización de su tratamiento posterior.

© Universidad Internacional de La Rioja (UNIR)

Test

1. La gestión de riesgos:

A. Crea y protege el valor.

B. Contribuye de manera intangible al logro de los objetivos.

C. Es una actividad independiente.

D. Es una responsabilidad exclusiva de la dirección.

2. ¿Cuál de las siguientes no forma parte del contexto externo de una organización?

A. La inestabilidad política.

B. Una situación de sequía permanente.

C. Un conflicto laboral sectorial.

D. Un cambio organizativo.

3. ¿Cuál de las siguientes no forma parte del contexto interno de una organización?

A. El CRM del que dispone la organización.

B. La relación con los clientes.

C. Un conflicto laboral con el comité de empresa.

D. Un cambio legislativo.

4. Un proceso de gestión de riesgos implantado según los principios y directrices de la UNE-ISO 31000 es una herramienta que ayuda a una organización a:

A. Garantizar la eficacia y la eficiencia operacional.

B. Conseguir una gestión reactiva.

C. Ser consciente de la necesidad de identificar y tratar el riesgo en toda la organización.

D. Eliminar la incertidumbre.

© Universidad Internacional de La Rioja (UNIR)

5. De acuerdo con la UNE-ISO 31000, ¿cuál de las siguientes actividades no se realiza en la fase de Diseño del Marco de Referencia de la Gestión de Riesgo?:

A. Asignación de roles

B. Asignación de recursos.

C. Establecimiento de los criterios de riesgo

D. Establecimiento de la comunicación y consulta.

6. La gestión de riesgos debe:

A. Formar parte de la toma de decisiones.

B. No trata explícitamente la incertidumbre.

C. Ser sistemática, irrepetible, ortodoxa y oportuna.

D. Ser independiente de factores humanos y culturales.

7. La finalidad de la valoración del riesgo es:

A. Ayudar a la toma de decisiones.

B. Determinar los criterios de riesgos a tratar.

C. Implantar las acciones de tratamiento del riesgo.

D. Todas las anteriores.

8. Las opciones de tratamiento del riesgo:

A. Se excluyen necesariamente unas a otras.

B. Son apropiadas en todas las circunstancias.

C. Incluyen la modificación de la probabilidad y las consecuencias.

D. No contemplan retener el riesgo.

© Universidad Internacional de La Rioja (UNIR)

9. En ISO 31000 la evaluación del riesgo comprende:

A. El establecimiento del contexto, la identificación, el análisis y la valoración del riesgo.

B. La identificación, el análisis y la valoración del riesgo.

C. La identificación, el análisis, la valoración y el tratamiento del riesgo.

D. El establecimiento del contexto, el análisis y el tratamiento del riesgo.

10. ¿La actividad de seguimiento y la revisión durante el proceso de gestión de riesgos según la norma UNE-ISO 31000:

A. Deberían realizarse durante la etapa de evaluación del riesgo.

B. Deberían realizarse durante la etapa de comunicación y consulta del proceso.

C. Deberían realizarse durante la etapa de definición del proceso.

D. Deberían realizarse en todas etapas del proceso.

© Universidad Internacional de La Rioja (UNIR)